Enterprise Network Penetration Test Report Executive Summary

Overview: An internal network penetration test was conducted against a simulated enterprise environment to evaluate the network's security posture, identify exploitable vulnerabilities, and assess possible attack vectors. The assessment included network reconnaissance, service enumeration, vulnerability identification, and packet-level traffic analysis using industry-standard tools including Nmap, Zenmap, and Wireshark.

Objectives:

- Identify active hosts, services, and network topology.
- Detect vulnerabilities and misconfigurations that could be leveraged by an attacker.
- Analyze network traffic for indicators of malicious activity.
- Assess the potential impact of identified security weaknesses.
- Provide actionable recommendations to reduce organizational risk.

Key Findings: The assessment identified three high-risk vulnerabilities and multiple indicators of active attack behavior including

- Legacy Windows Server systems with known security vulnerabilities.
- Anonymous FTP access enabled on the file server, allowing unauthorized access to resources.
- Unencrypted HTTP services exposing sensitive data and credentials to interception.
- Unauthorized network reconnaissance activity consistent with Nmap scanning detected.
- Use of legacy SSH protocols presenting cryptographic vulnerabilities.
- Potential Denial-of-Service (DoS) activity targeting critical infrastructure detected.

Risk Assessment: The identified vulnerabilities could enable attackers to gain unauthorized access, escalate privileges, intercept sensitive information, disrupt business operations, and compromise critical systems. The presence of reconnaissance activity and attack indicators demonstrates a realistic attack path from initial discovery through exploitation and service disruption.

Recommendations: To improve the organization's security posture, the following actions are recommended

- Upgrade or patch legacy Windows Server systems.
- Replace FTP with secure alternatives such as SFTP.
- Enforce HTTPS across all web services.
- Disable insecure SSH versions and weak cryptographic protocols.
- Implement Multi-Factor Authentication (MFA).
- Deploy firewall protections, IDS/IPS, and security monitoring solutions.

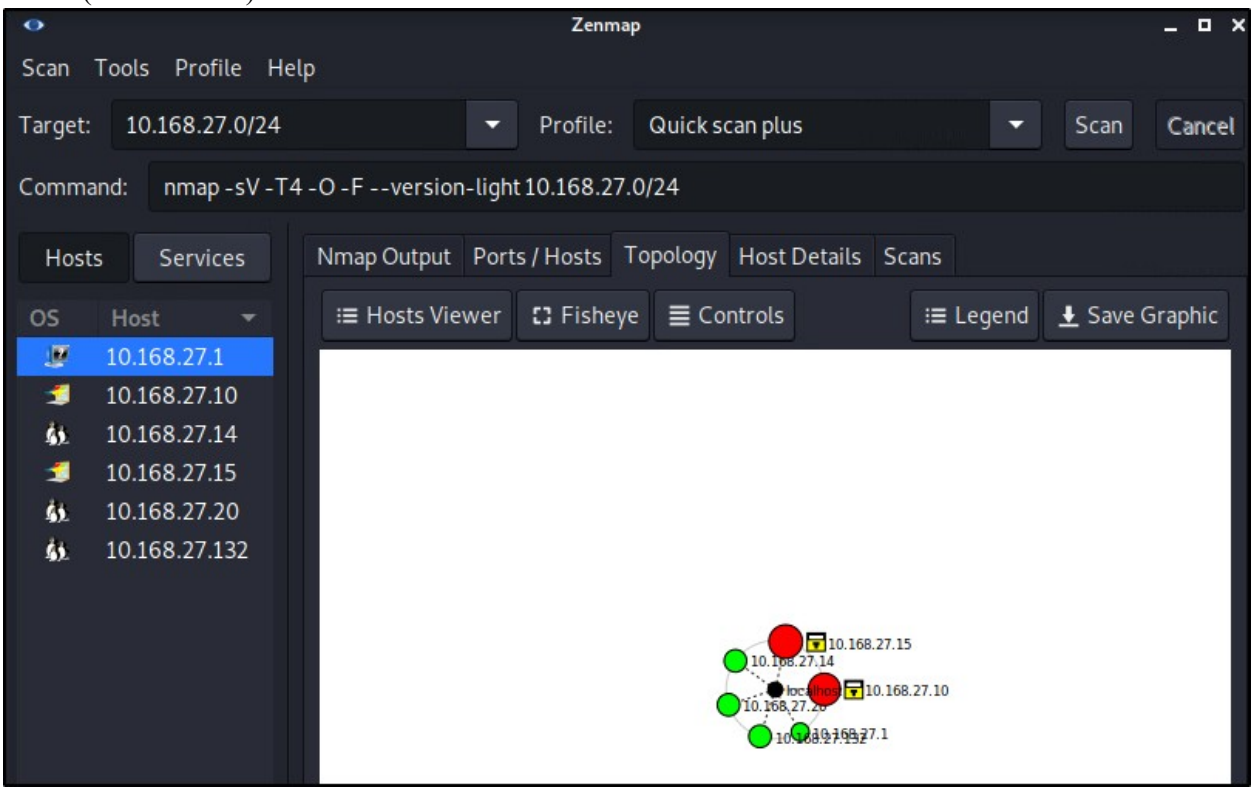
Conclusion:

The assessment demonstrated that several security weaknesses could be exploited by a motivated attacker to compromise the confidentiality, integrity, and availability of company data. Implementing the recommended remediation measures will significantly reduce organizational risk and improve network resilience against future threats.

Disclaimer: This assessment was conducted within a controlled educational/laboratory environment designed for cybersecurity training and research purposes. No production systems were targeted.

A. Network Reconnaissance

First, I performed host discovery and service enumeration scans via zenmap on the 10.168.27.0/24 subnet. The scan results show six devices in a star topology on the local network: four Linux workstations (including my own), a local domain controller (10.168.27.10), and a machine configured as a file & web server (10.168.27.15).



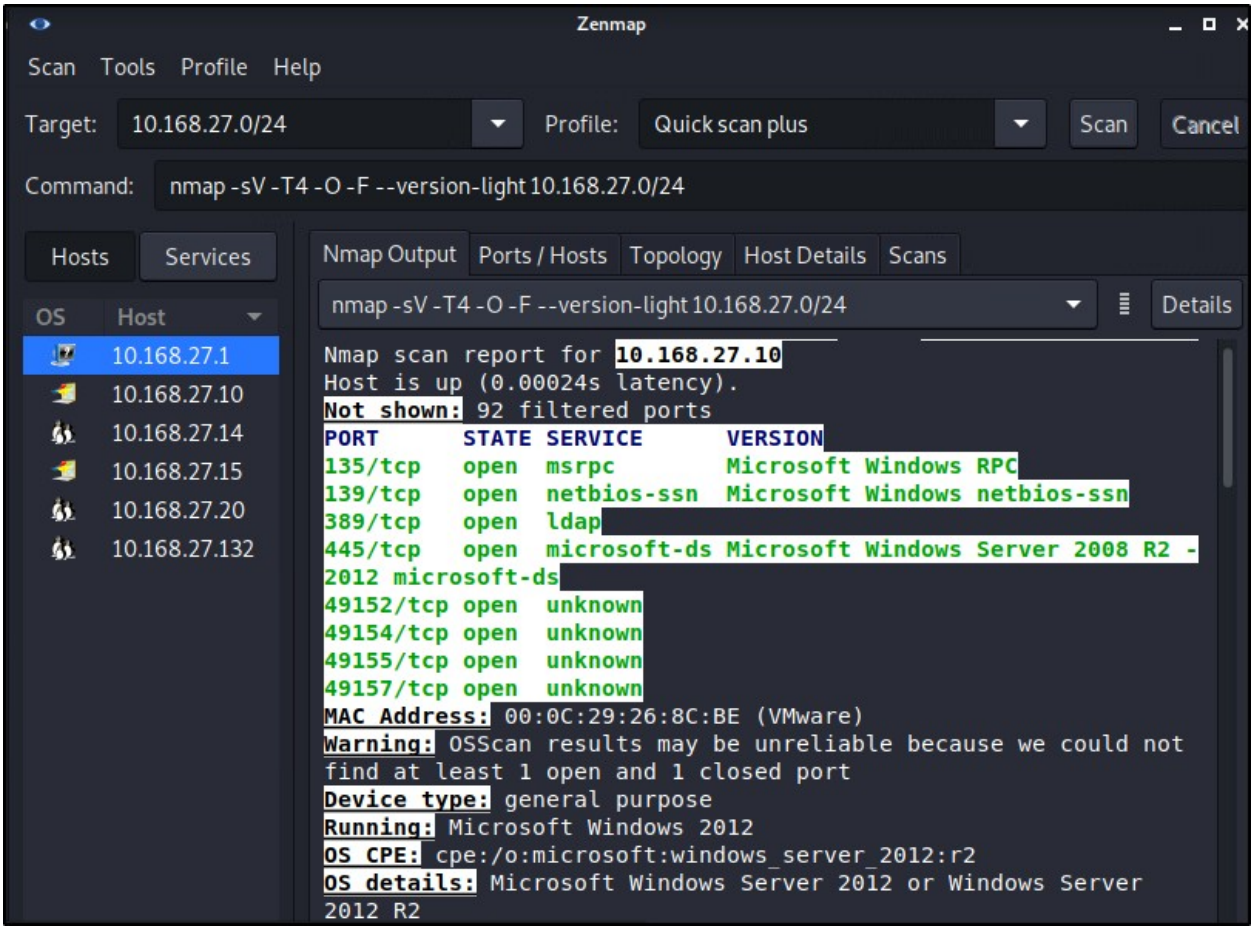
After analyzing the scan results, three security concerns were noted:

1. The domain controller is running a vulnerable version of Windows Server OS.
2. The file/web server is using an insecure file-sharing protocol.
3. The file/web server is also using an unprotected web server protocol.

Vulnerability	CVSS Score
Legacy Windows Server	9.8 Critical
Anonymous FTP	8.0 High
HTTP Service	7.5 High

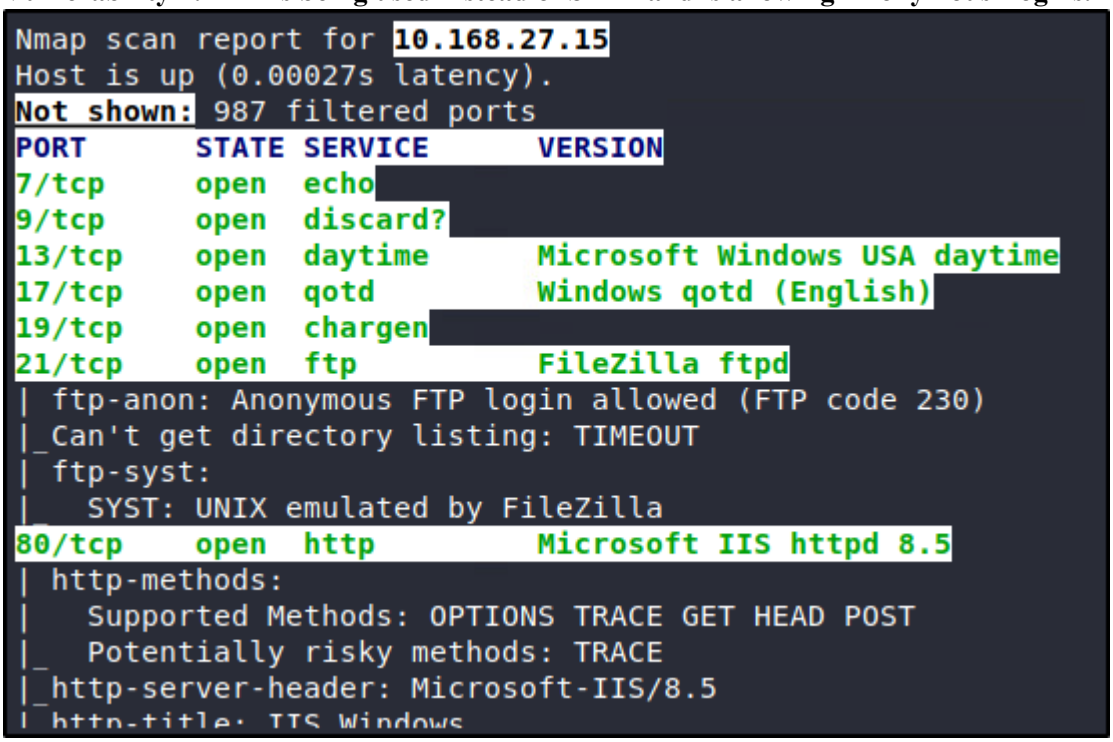
B. Summary of Vulnerabilities and Implications

Vulnerability 1: Domain Controller (10.168.27.10) is running a vulnerable version of Windows Server.



The company's domain controller at 10.168.27.10 appears to be running Windows Server 2008, 2012 or 2012 RS. All three Operating Systems are vulnerable to the exploit "CVE-2019-0584". **This is a critical vulnerability with a CVSS score of 9.8.** Successful compromise of the domain controller could result in complete loss of authentication services, unauthorized privilege escalation, disruption of business operations, and exposure of sensitive organizational data.

Vulnerability 2: FTP is being used instead of SFTP and is allowing Anonymous Logins.



The host configured as a file/web server at 10.168.27.15 appears to be using the File Transfer Protocol (FTP). Data transmitted via FTP is not encrypted and can thus be intercepted and used to further the attacker's goals. **This is a high-risk vulnerability with a CVSS score of 8.0.** Currently, company data and possibly credentials are being broadcast in a manner that can be read by an attacker.

On a related note, this server also allows for anonymous FTP logins. Anonymous authentication permits unauthorized users to access hosted resources without credential validation; accessing this server also provides a bridgehead for further attacks on the device and the company network.

Vulnerability 3: HTTP is being used instead of HTTPS.

```
Nmap scan report for 10.168.27.15
Host is up (0.00018s latency).
Not shown: 90 filtered ports
PORT      STATE SERVICE      VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime      Microsoft Windows USA daytime
21/tcp    open  ftp          FileZilla ftpd
80/tcp    open  http         Microsoft IIS httpd 8.5
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup:
WORKGROUP)
49154/tcp open  unknown
49155/tcp open  unknown
```

The host configured as a file/web server at 10.168.27.15 also appears to be running a web server via HTTP, another unsafe protocol. This is similar to the FTP issue noted above. **This is a high-risk vulnerability with a CVSS score of 7.5.** Sensitive company information is being transmitted in an unencrypted manner that can be seen and stolen by the attacker. Intercepted credentials may facilitate lateral movement and privilege escalation activities.

Steps to remediate the vulnerabilities noted above are discussed in Section D of the report.

Next, I used a tool called Wireshark to inspect the traffic flowing across the company network.

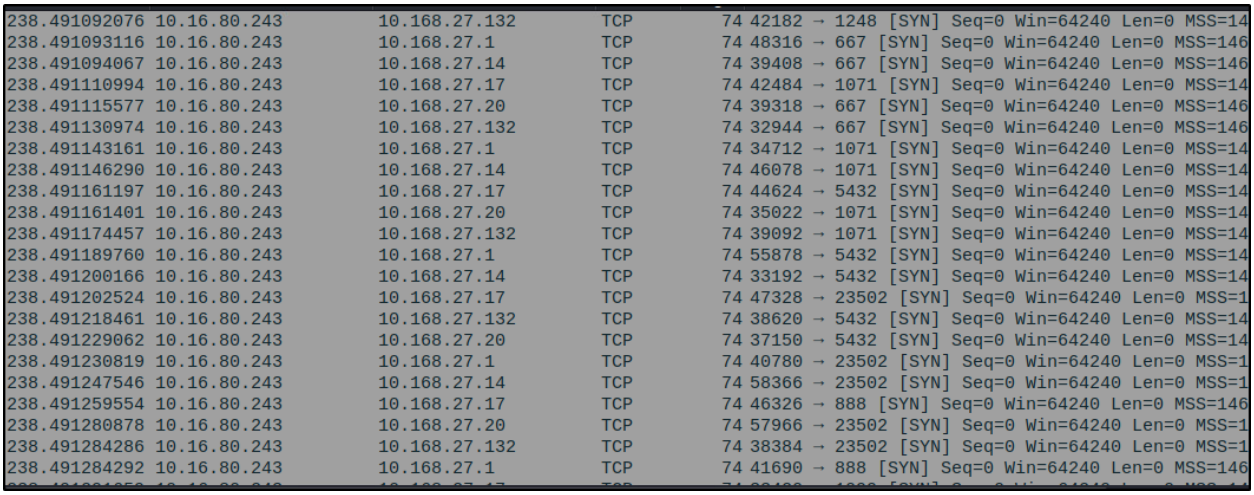
C. Anomalies Found in Packet Capture File

After inspecting network traffic via Wireshark, the details were saved to a Packet Capture (PCAP) file for analysis. After reviewing the data, three anomalies were noted:

1. At the time of inspection, an unauthorized device was also scanning the network with the nmap tool.
2. That same unauthorized device had located a vulnerable version of the SSH protocol on the company's network and was actively trying to exploit it.
3. The unauthorized device was also performing a Denial of Service (DoS) attack on the company's domain controller.

Further details provided below.

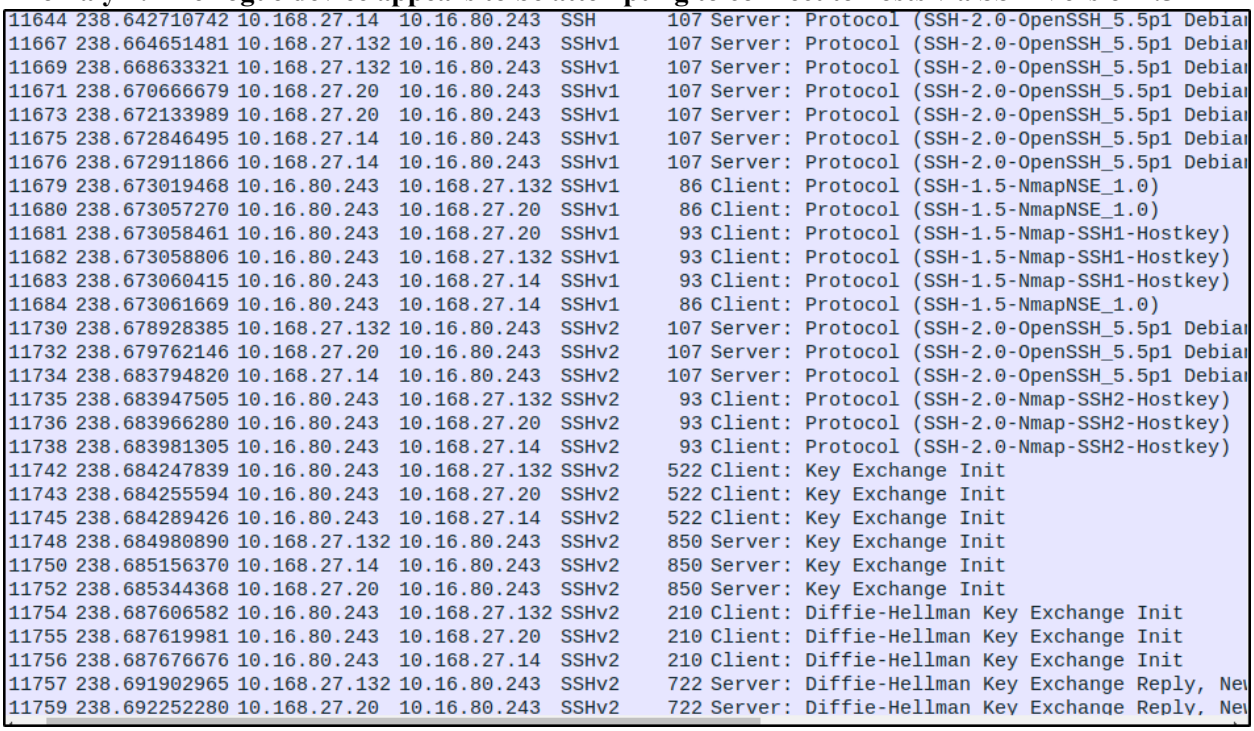
Anomaly 1: Unauthorized device appears to be scanning the company network via nmap.



```
238.491092076 10.16.80.243    10.168.27.132    TCP    74 42182 → 1248 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491093116 10.16.80.243    10.168.27.1      TCP    74 48316 → 667 [SYN] Seq=0 Win=64240 Len=0 MSS=146
238.491094067 10.16.80.243    10.168.27.14     TCP    74 39408 → 667 [SYN] Seq=0 Win=64240 Len=0 MSS=146
238.491110994 10.16.80.243    10.168.27.17     TCP    74 42484 → 1071 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491115577 10.16.80.243    10.168.27.20     TCP    74 39318 → 667 [SYN] Seq=0 Win=64240 Len=0 MSS=146
238.491130974 10.16.80.243    10.168.27.132    TCP    74 32944 → 667 [SYN] Seq=0 Win=64240 Len=0 MSS=146
238.491143161 10.16.80.243    10.168.27.1      TCP    74 34712 → 1071 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491146290 10.16.80.243    10.168.27.14     TCP    74 46078 → 1071 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491161197 10.16.80.243    10.168.27.17     TCP    74 44624 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491161401 10.16.80.243    10.168.27.20     TCP    74 35022 → 1071 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491174457 10.16.80.243    10.168.27.132    TCP    74 39092 → 1071 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491189760 10.16.80.243    10.168.27.1      TCP    74 55878 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491200166 10.16.80.243    10.168.27.14     TCP    74 33192 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491202524 10.16.80.243    10.168.27.17     TCP    74 47328 → 23502 [SYN] Seq=0 Win=64240 Len=0 MSS=1
238.491218461 10.16.80.243    10.168.27.132    TCP    74 38620 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491229062 10.16.80.243    10.168.27.20     TCP    74 37150 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=14
238.491230819 10.16.80.243    10.168.27.1      TCP    74 40780 → 23502 [SYN] Seq=0 Win=64240 Len=0 MSS=1
238.491247546 10.16.80.243    10.168.27.14     TCP    74 58366 → 23502 [SYN] Seq=0 Win=64240 Len=0 MSS=1
238.491259554 10.16.80.243    10.168.27.17     TCP    74 46326 → 888 [SYN] Seq=0 Win=64240 Len=0 MSS=146
238.491280878 10.16.80.243    10.168.27.20     TCP    74 57966 → 23502 [SYN] Seq=0 Win=64240 Len=0 MSS=1
238.491284286 10.16.80.243    10.168.27.132    TCP    74 38384 → 23502 [SYN] Seq=0 Win=64240 Len=0 MSS=1
238.491284292 10.16.80.243    10.168.27.1      TCP    74 41690 → 888 [SYN] Seq=0 Win=64240 Len=0 MSS=146
```

There appears to be an unauthorized device (10.16.80.243) scanning the network in a manner that suggests a reconnaissance is in progress. The attacker has already managed to infiltrate the network and appears to be moving from reconnaissance to exploitation phase.

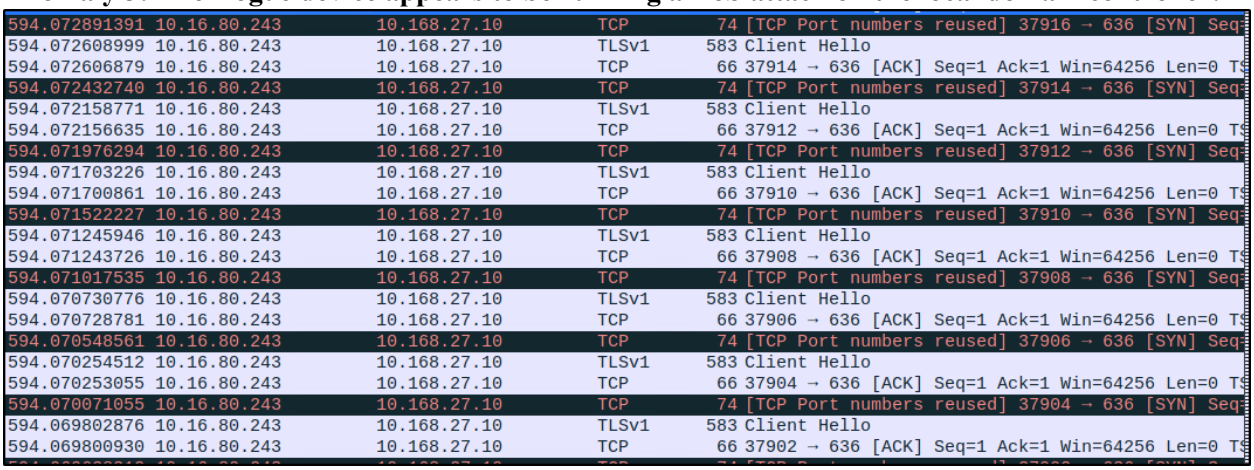
Anomaly 2: The rogue device appears to be attempting to connect to hosts via SSH Version1.5



11644	238.642710742	10.168.27.14	10.16.80.243	SSH	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11667	238.664651481	10.168.27.132	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11669	238.668633321	10.168.27.132	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11671	238.670666679	10.168.27.20	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11673	238.672133989	10.168.27.20	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11675	238.672846495	10.168.27.14	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11676	238.672911866	10.168.27.14	10.16.80.243	SSHv1	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11679	238.673019468	10.16.80.243	10.168.27.132	SSHv1	86	Client: Protocol (SSH-1.5-NmapNSE_1.0)
11680	238.673057270	10.16.80.243	10.168.27.20	SSHv1	86	Client: Protocol (SSH-1.5-NmapNSE_1.0)
11681	238.673058461	10.16.80.243	10.168.27.20	SSHv1	93	Client: Protocol (SSH-1.5-Nmap-SSH1-Hostkey)
11682	238.673058806	10.16.80.243	10.168.27.132	SSHv1	93	Client: Protocol (SSH-1.5-Nmap-SSH1-Hostkey)
11683	238.673060415	10.16.80.243	10.168.27.14	SSHv1	93	Client: Protocol (SSH-1.5-Nmap-SSH1-Hostkey)
11684	238.673061669	10.16.80.243	10.168.27.14	SSHv1	86	Client: Protocol (SSH-1.5-NmapNSE_1.0)
11730	238.678928385	10.168.27.132	10.16.80.243	SSHv2	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11732	238.679762146	10.168.27.20	10.16.80.243	SSHv2	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11734	238.683794820	10.168.27.14	10.16.80.243	SSHv2	107	Server: Protocol (SSH-2.0-OpenSSH_5.5p1 Debia
11735	238.683947505	10.16.80.243	10.168.27.132	SSHv2	93	Client: Protocol (SSH-2.0-Nmap-SSH2-Hostkey)
11736	238.683966280	10.16.80.243	10.168.27.20	SSHv2	93	Client: Protocol (SSH-2.0-Nmap-SSH2-Hostkey)
11738	238.683981305	10.16.80.243	10.168.27.14	SSHv2	93	Client: Protocol (SSH-2.0-Nmap-SSH2-Hostkey)
11742	238.684247839	10.16.80.243	10.168.27.132	SSHv2	522	Client: Key Exchange Init
11743	238.684255594	10.16.80.243	10.168.27.20	SSHv2	522	Client: Key Exchange Init
11745	238.684289426	10.16.80.243	10.168.27.14	SSHv2	522	Client: Key Exchange Init
11748	238.684980890	10.168.27.132	10.16.80.243	SSHv2	850	Server: Key Exchange Init
11750	238.685156370	10.168.27.14	10.16.80.243	SSHv2	850	Server: Key Exchange Init
11752	238.685344368	10.168.27.20	10.16.80.243	SSHv2	850	Server: Key Exchange Init
11754	238.687606582	10.16.80.243	10.168.27.132	SSHv2	210	Client: Diffie-Hellman Key Exchange Init
11755	238.687619981	10.16.80.243	10.168.27.20	SSHv2	210	Client: Diffie-Hellman Key Exchange Init
11756	238.687676676	10.16.80.243	10.168.27.14	SSHv2	210	Client: Diffie-Hellman Key Exchange Init
11757	238.691902965	10.168.27.132	10.16.80.243	SSHv2	722	Server: Diffie-Hellman Key Exchange Reply, Ne
11759	238.692252280	10.168.27.20	10.16.80.243	SSHv2	722	Server: Diffie-Hellman Key Exchange Reply, Ne

The rogue device at 10.16.80.243 appears to be using the nmap scripting engine (NSE) tool to establish connections with vulnerable hosts running insecure versions of the SSH protocol (packet numbers 11634-11962), with some success. This means devices on the network are still using outdated SSH protocols or are allowing backwards compatibility (using a more recent version of SSH, but still allowing older versions to connect successfully). The NSE was also able to extract the SSH host keys used by the device that allow SSHv1.5. **If the attacker compromises the encryption used on this network, the attacker can create encrypted tunnels to other machines in order to hide his malicious traffic or create a secure tunnel for stealing data.**

Anomaly 3: The Rogue device appears to be running a DoS attack on the local domain controller:



594.072891391	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37916 → 636 [SYN] Seq
594.072608999	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.072606879	10.16.80.243	10.168.27.10	TCP	66	37914 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.072432740	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37914 → 636 [SYN] Seq
594.072158771	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.072156635	10.16.80.243	10.168.27.10	TCP	66	37912 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.071976294	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37912 → 636 [SYN] Seq
594.071703226	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.071700861	10.16.80.243	10.168.27.10	TCP	66	37910 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.071522227	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37910 → 636 [SYN] Seq
594.071245946	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.071243726	10.16.80.243	10.168.27.10	TCP	66	37908 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.071017535	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37908 → 636 [SYN] Seq
594.070730776	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.070728781	10.16.80.243	10.168.27.10	TCP	66	37906 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.070548561	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37906 → 636 [SYN] Seq
594.070254512	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.070253055	10.16.80.243	10.168.27.10	TCP	66	37904 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS
594.070071055	10.16.80.243	10.168.27.10	TCP	74	[TCP Port numbers reused] 37904 → 636 [SYN] Seq
594.069802876	10.16.80.243	10.168.27.10	TLSv1	583	Client Hello
594.069800930	10.16.80.243	10.168.27.10	TCP	66	37902 → 636 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TS

The unauthorized device at 10.16.80.243 appears to be spamming the company's domain controller at 10.168.27.10 with hundreds of thousands of identical SYN and ACK requests (Packet Range 16894-213804). The attacker appears to be conducting a Denial-of-Service (DoS) attack against the server. Denial of Service attacks occur when attackers try to disable a resource; in this case, it appears the attacker is flooding the domain controller with traffic, attempting to exhaust system resources and disrupt authentication services. **If the attack is successful, it will paralyze the company's network by disrupting its core identity and authentication system**. Such disruption could provide opportunities for additional malicious activities and operational impact.

In the following section, I will recommend solutions to the vulnerabilities and anomalies found during the assessment.

D. Recommended Solutions

Current Risk Matrix

Likelihood	Impact	Risk
High	Critical	Legacy Windows Server
High	High	Anonymous FTP
High	High	HTTP
Medium	High	SSHv1
High	Critical	DoS Attack

Vulnerability 1

Windows Server 2008 and 2012 are vulnerable Operating Systems. Microsoft has published multiple patches for these, but they have not been applied to the company's server. If the organization can afford it, a newer OS that has proven secure can be purchased and installed; regardless of the OS chosen, it must be kept patched and regularly audited for vulnerabilities.

Vulnerability 2

The web-enabled file server should have FTP disabled and replaced with the latest version of Secure FTP (SFTP). SFTP performs the same function as FTP but does so using encryption. SFTP should be configured to disable anonymous logins. Alternately, migrating to a Cloud-based File Server can eliminate the need for a File Server on the company's network, thus limiting the network's attack surface.

Vulnerability 3

The web-enabled file server should be using HTTPS instead of HTTP or should disable this function altogether if it is not necessary. Additionally, some form of Multi-Factor Authentication should be implemented to ensure only authorized users can access these files. As noted above, if users access the server via the Internet, it may be safer to implement a Cloud-based file server secured by a third party.

Anomaly 1

The company's internal network is being scanned by an attacker via the Internet. This is because the network does not have any protection from malicious internet traffic. Implementing a Firewall and an Intrusion Detection /Prevention System (IDS/IPS) can help. A Firewall filters traffic between the company's internal network and the Internet. An IDS would monitor internal traffic for malicious activity that made it past the Firewall; the IPS could move to intercept attacks in progress. Additionally, the individual devices on the company network need to be examined and reconfigured securely.

Anomaly 2

This network would benefit from up-to-date versions of SSH, and backwards compatibility should be disabled. The default port for SSH should also be changed since port 22 is well-known, and there should be a limit on number of login attempts to mitigate brute-force (password-guessing) attacks.

Anomaly 3

The local domain controller appears to be experiencing a DoS attack. Short-term, the attacker's IP address should be blocked from sending traffic on this network. Long-term, a commercially available DoS mitigation service can also be contracted to help prevent future attacks. Additionally, stricter access controls should be configured and implemented. A domain controller should not be accessible from the Internet. The attack surface of this critical node should also be hardened. Port 636 should be closed, since it is used for obsolete SSL connections, and an Access Control List should be implemented to ensure only authorized users are permitted to access this authentication server.